Internet das coisas

Segurança no Desenvolvimento de Software

Introdução a Segurança da Informação

Prof. Ana Beatriz Morais

AGO/2026

SENAI
PELO FUTURO DO TRABALHO

Quem vai acompanhar vocês nessa jornada?

- 🎓 **Formação**
  - Técnico em Informática
  - Bacharel em Ciência da Computação
- 📚 **Estudando atualmente:**
  - Pós Graduação em Cybersegurança e Governança de Dados
- 💼 **No dia a dia eu sou...**
  - Desenvolvedora de Software na DOC9
  - Coordenadora de TI no Multihospital de Florianópolis
  - Professora no SENAI/SC



O que veremos hoje

- O que é segurança em desenvolvimento?
- Por que os desenvolvedores precisam saber?
- Custos de uma falha de segurança.
- Prática
- Lista de atividades



O que é segurança em desenvolvimento?

O que é segurança no desenvolvimento de um software?

- Você pode construir uma casa linda, funcional, rápida, mas se a porta da frente não tranca, não importa quão bonita ela é.
- **Segurança não é "um recurso a mais" do sistema, é parte da fundação. Não dá pra "adicionar segurança depois", assim como não dá pra adicionar fundação depois que a casa já está de pé.**



O que é segurança no desenvolvimento de um software?

- Porta = ponto de entrada.
  - login, formulário, endpoint de API
- Fechadura = autenticação;
- Grade na janela = Validação dos dados;
- Câmera = log de monitoramento
- Cofre dentro de casa = criptografia dos dados sensíveis



O que é segurança no desenvolvimento de um software?

- A segurança no desenvolvimento de software é a prática de integrar regras, ferramentas e processos de proteção em todas as etapas da criação de um sistema. O objetivo principal é impedir falhas e ataques antes que o programa fique pronto e seja usado pelo público.
- **Pilares Principais**
  - Confidencialidade: Garantir que só pessoas autorizadas vejam os dados.
  - Integridade: Proteger as informações para que não sejam alteradas ou apagadas por engano ou fraude.
  - Disponibilidade: Fazer o sistema funcionar sempre que o usuário precisar.

O que é segurança no desenvolvimento de um software?

- Riscos e vulnerabilidades mais comuns: São necessários realizar práticas de cibersegurança para manter o sistema mais protegido e resistente a ataques e vulnerabilidades.
- **Injeção de SQL:** É uma técnica de ataque cibernético que explora vulnerabilidades em aplicações que interagem com bancos de dados SQL.
- **Cross-Site Scripting (XSS):** É uma vulnerabilidade de segurança da web que permite que invasores injetem scripts maliciosos em páginas da web visualizadas por outros usuários.

O que é segurança no desenvolvimento de um software?

- **Autenticação quebrada:** São falhas em sistemas de autenticação, utilizadas para o usuário entrar com sua senha e depois o sistema solicita um código, é o que chamamos de verificação de 2 fatores, e quando ela é quebrada facilita que os hackers acessem contas de usuários ou sistemas sem autorização.
- **Exposição de dados sensíveis:** Armazenamento ou transmissão inadequada de dados confidenciais, como senhas, informações de cartão de crédito ou dados pessoais.
- **Controle de acesso inadequado:** São falhas em sistemas de controle de acesso que permitem que os usuários não autorizados acessem recursos ou funcionalidades restritas.

Por que os desenvolvedores precisam saber?

Por que os desenvolvedores precisam saber?

- Um eletricista que não entende de segurança elétrica não erra "um pouco", ele constrói uma casa que pode pegar fogo. O usuário final só aperta o interruptor e confia que tá tudo certo por trás.
- O desenvolvedor é o eletricista do sistema. O usuário nunca vai perguntar "essa senha está com hash?", ele confia que você, que construiu, pensou nisso.



Por que os desenvolvedores precisam saber?

- Segurança não é só trabalho do time de segurança, em times pequenos, não existe "time de segurança". É o próprio dev.



Por que os desenvolvedores precisam saber?

- Os desenvolvedores precisam saber segurança para criar sistemas confiáveis que protegem os dados dos usuários contra invasões e bloqueiam falhas críticas antes que o software chegue ao mercado.
- Por que a Segurança é Essencial
  - Proteção de Dados:
    - Evita vazamentos de senhas e informações pessoais.
    - Mantém a confiança do cliente no sistema.
    - Cumpre leis rígidas de privacidade.
  - Qualidade do Código
    - Reduz custos para corrigir erros graves depois.
    - Impede ataques comuns como invasões de banco de dados.
    - Garante que o sistema funcione sem quedas.

Custos de uma falha de segurança



SENAI

Custos de uma falha de segurança

- Uma simples analogia: **buraco no casco de um barco**.
  - Um furo pequeno não afunda o barco na hora, mas quanto mais tempo sem consertar, mais água entra, e o custo de resolver cresce exponencialmente.



Custos de uma falha de segurança

- **Algumas empresas que passaram por ataque hacker**
  - Yahoo (2013–2016) — 3 bilhões de contas comprometidas em dois incidentes. Custo: desvalorização de US$ 350 milhões na venda da empresa para a Verizon.
  - Uber (2016, revelado em 2017) — 57 milhões de usuários e motoristas afetados. A empresa escondeu o caso pagando US$ 100 mil aos hackers para ficarem calados. Multa ao ser descoberta: US$ 148 milhões.
  - Sony PlayStation Network (2011) — o serviço foi invadido e dados de 77 milhões de usuários foram vazados, incluindo números de cartão de crédito. O serviço ficou fora do ar por cerca de 3 semanas, causando prejuízo estimado em US$ 170 milhões.

Custos de uma falha de segurança

- **Algumas empresas que passaram por ataque hacker**
  - JBS (Brasil/EUA, 2021) — ataque de ransomware do grupo REvil parou operações na Austrália, Canadá e EUA. A empresa admitiu ter pago US$ 11 milhões (na época, ~R$ 56 milhões) em bitcoins para evitar vazamento de dados.
  - Lojas Renner (Brasil, 2021) — ataque de ransomware derrubou mais de 2 mil servidores e paralisou o sistema por dias. O pedido de resgate teria sido de US$ 1 bilhão (valor não confirmado oficialmente); a empresa afirma não ter pago nada. Gasto declarado em segurança cibernética após o ataque: R$ 14 milhões.
  - STJ — Superior Tribunal de Justiça (Brasil, 2020) — ransomware sequestrou mais de 1.200 servidores e destruiu backups. Sistemas ficaram fora do ar por 7 dias. Mostra que nem instituição pública/judiciário está imune.
  - Embraer (Brasil, 2020) — atingida pelo mesmo grupo que atacou o STJ. A empresa optou por não pagar resgate e restaurar backups — mas isso resultou em vazamento de 460 MB de dados privados.

Custos de uma falha de segurança

- **1. Custo financeiro direto**
  - Multas regulatórias (LGPD no Brasil, GDPR na Europa)
  - Pagamento de resgate em ataques de ransomware
  - Contratação emergencial de especialistas/consultoria de segurança
  - Indenização a clientes afetados
  - Exemplos já levantados: Equifax pagou até US$ 700 milhões; JBS pagou US$ 11 milhões de resgate; British Airways foi multada em £20 milhões.
- **2. Custo operacional (parada de sistema)**
  - Sistema fora do ar = empresa parada = zero receita naquele período
  - Equipe inteira desviada para apagar incêndio em vez de desenvolver produto.

Custos de uma falha de segurança

- **3. Custo de reputação**
  - Cliente perde confiança e migra psra concorrente
  - Imprensa noticia o caso, a marca vira sinônimo do vazamento (ex.: "aquele vazamento da Renner")
  - Empresas pequenas podem simplesmente não sobreviver ao dano de imagem
- **4. Custo legal**
  - Processos individuais e coletivos de clientes afetados
  - Investigação de órgãos reguladores (no Brasil, a ANPD)
  - Obrigação de notificar publicamente o incidente
  - Exemplo: Uber pagou US$ 148 milhões de multa justamente por tentar esconder um vazamento em vez de reportar.

Custos de uma falha de segurança

- **5. Custo de oportunidade**
  - Tempo do time de dev gasto corrigindo o que deveria ter sido feito certo desde o início
  - Atraso em lançamentos e roadmap
  - Correção emergencial custa muito mais caro que prevenção, o mesmo bug que se corrige em 5 min em desenvolvimento pode levar semanas em produção.

Prática

Praticando

- 1. Criar conta
  - Acesse o site: portswigger.net/web-security e crie uma conta gratuita.
  - Clique em algum botão de cadastro/login no canto superior direito
  - Crie a conta com e-mail e senha (gratuito, sem cartão)
- 2. Entrar na Academy
  - No menu superior, clique em "Academy"
  - Vai abrir a lista de tópicos (SQL injection, XSS, Authentication, etc.)
- 3. Escolher o tópico
  - Clique em "SQL injection"
  - Role até achar o lab: "SQL injection vulnerability in WHERE clause allowing retrieval of hidden data" e clique nele

Praticando

- 4. Acessar o ambiente do lab
  - Dentro da página do lab, clique no botão "Access the lab"
  - Abre uma nova aba com uma loja fake, em uma URL tipo https://[código-aleatório].web-security-academy.net/
- 5. Explorar o site normal
  - Clique em qualquer categoria (ex. "Gifts")
  - Observe a URL: vai ter algo como ?category=Gifts no final
- 6. Fazer o ataque
  - Clique na barra de endereço do navegador
  - Troque o final da URL de **?category=Gifts** para:
    - **?category=Gifts'+OR+1=1–**
  - Aperte enter
- 7. Ver o resultado
  - A página recarrega mostrando produtos extras (os "escondidos")
  - Aparece um banner verde no topo: "Congratulations, you solved this lab!"

Lista de atividades



Lista de atividades

1. Liste 5 portas de entradas de um sistema e explique como ela está trancada.
2. Estudo de caso curto: um sistema vazou dados porque o dev não validou input no back-end, só no front. Isso é falha do dev, do time de QA, ou do "sistema" de forma abstrata? Justifique.
3. Dado um cenário fictício (empresa com 50 mil usuários, vazamento de CPF e e-mail), liste quais tipos de custo essa empresa provavelmente vai enfrentar dê um exemplo concreto de cada um nesse cenário específico.
4. Explique, com suas palavras, por que "o usuário nunca vai perguntar se a senha dele está com hash" é um argumento a favor do desenvolvedor pensar em segurança por conta própria, mesmo sem ninguém pedir.
5. Durante a aula, vimos um ataque de SQL Injection funcionando ao vivo, só editando a URL. Depois de ver isso na prática, o que mudou na sua forma de pensar sobre "só um campo de formulário simples"?
6. Vimos dois exemplos reais de empresas atacadas por ransomware que tomaram decisões diferentes (uma pagou o resgate, outra não). Se você fosse o desenvolvedor responsável pelo sistema atacado, não quem decide se paga ou não, mas quem construiu o sistema, o que dessa situação poderia ter sido evitado antes de o ataque acontecer?
7. Por que armazenar chaves de API e senhas de banco de dados diretamente no código-fonte (em vez de em variáveis de ambiente) é considerado uma má prática de segurança, mesmo em um repositório privado?
8. O que significa "nunca confiar no input do usuário"? Cite um exemplo prático de um campo de formulário comum (nome, e-mail, comentário) que pode virar um vetor de ataque se não for tratado corretamente.

SENAI

Serviço Nacional de Aprendizagem Industrial

PELO FUTURO DO TRABALHO

0800 048 1212 **sc.senai.br**

Rodovia Admar Gonzaga, 2765 - Itacorubi - 88034-001 - Florianópolis, SC